CEUB

EDUCAÇÃO SUPERIOR

# Fundamentos de SI

Prof. Henrique Evaristo

ceub.br

# Fundamentos de SI

## Ataques e Ameaças

# CATEGORIAS DE ATAQUE

Os atores da ameaça podem usar as ferramentas mencionadas anteriormente ou uma combinação de ferramentas para criar vários ataques

Uma classificação comum em relação aos ataques à segurança é a seguinte :

**Ataques PASSIVOS**

Possui como objetivo a **descoberta** ou a utilização de informações do sistema atacado **sem afetar os recursos** desse sistema.

**Ataques ATIVOS**

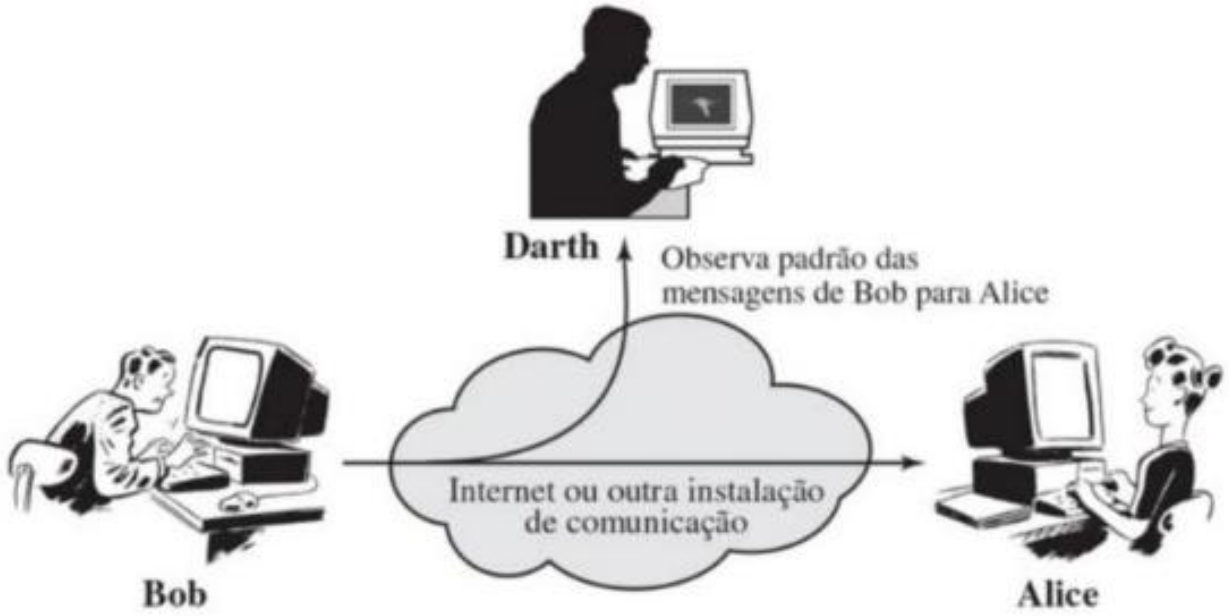
No ataque ativo, além de obter as informações, **modificam-se os recursos** do sistema e, com isso, influenciam sua operação.

# Ataques Passivos

- Possuem a **natureza de monitoramento e bisbilhotagem de transmissões**, com foco na obtenção das informações quando são transmitidas
- Um tipo de ataque passivo é a liberação de conteúdo da mensagem, no qual existe um acesso não autorizado da informação.
- Qualquer comunicação, seja uma conversa telefônica, um texto ou um arquivo, pode conter informações confidenciais e críticas, que se deve impedir que alguém tenha acesso a essas informações.

# Ataque passivo - análise de tráfego

Nesse caso, as informações estão protegidas, de forma que o oponente não irá conseguir extrair as informações, mesmo se capturar a mensagem. Entretanto o oponente pode levantar informações do padrão de mensagens, como a frequência de envio, o tamanho da mensagem, os envolvidos na comunicação. A Figura a seguir ilustra essa situação:




Fonte: (STALLINGS, 2008, p. 6).

# Ataques Passivos

*Os ataques passivos são de **difícil detecção**, já que não há nenhuma alteração no sistema.*

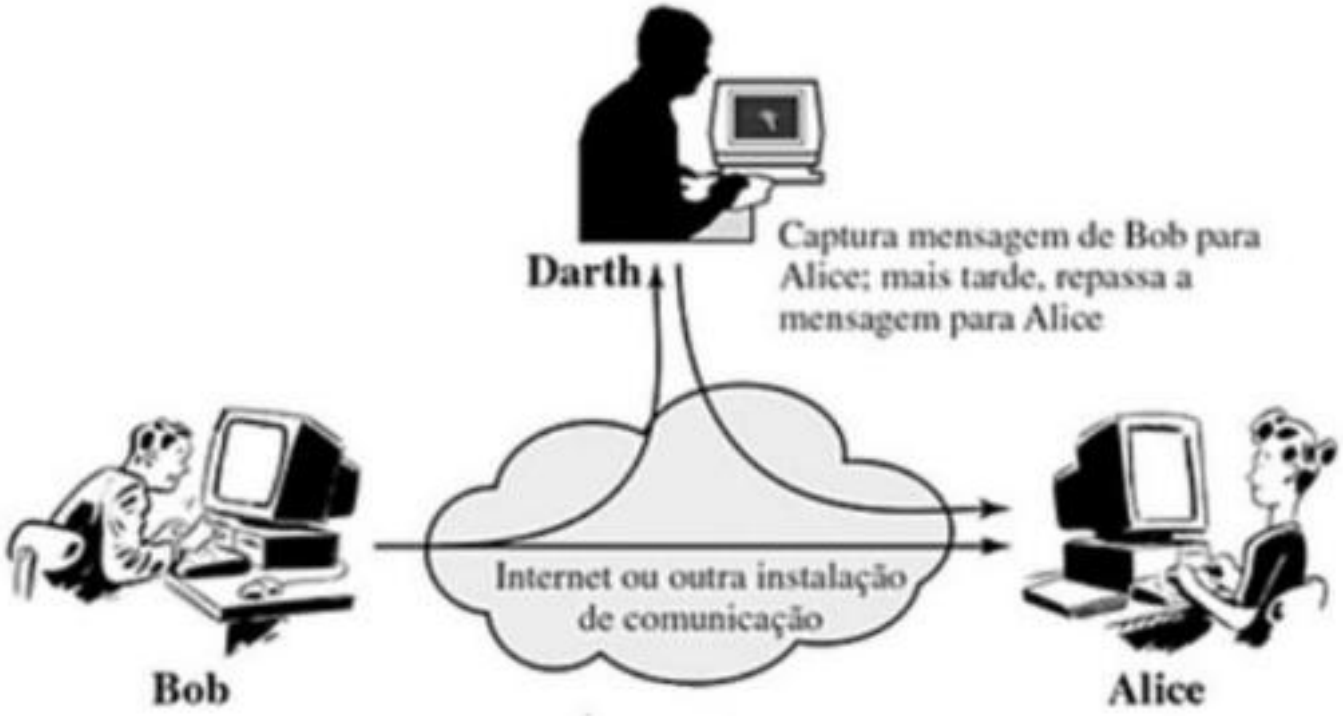
*Como não é possível impedir esse tipo de ataque, **deve-se atuar na prevenção**, utilizando **criptografia** para que mesmo com a captura da mensagem não seja possível ter as informações dessa mensagem, **protegendo a confidencialidade.***

# Ataques Ativos

- Ocorre modificação no fluxo de dados ou criação de um fluxo falso .
- Pode ser classificado em quatro categorias :
  - Repetição
  - Disfarce
  - Modificação de mensagens
  - Negação de serviço

# Ataque Ativo - Repetição

- No ataque de repetição , existe inicialmente uma captura passiva de dados que , posteriormente , serão retransmitidas para produzir um efeito não autorizado




Fonte: (STALLINGS, 2008, p. 7).

# Ataque Ativo – Disfarce (*Masquerading*)

- Uma entidade finge ser outra entidade, visando permitir ao atacante a execução de ações em nome desta entidade .

- Após o usuário conseguir se autenticar com uma entidade pertencente a rede, obterá alguns privilégios de acesso adicionais, os quais não seriam concedidos sem as credenciais

# Ataque Ativo – Disfarce (*Masquerading*)

Fonte: (STALLINGS, 2008, p. 7).

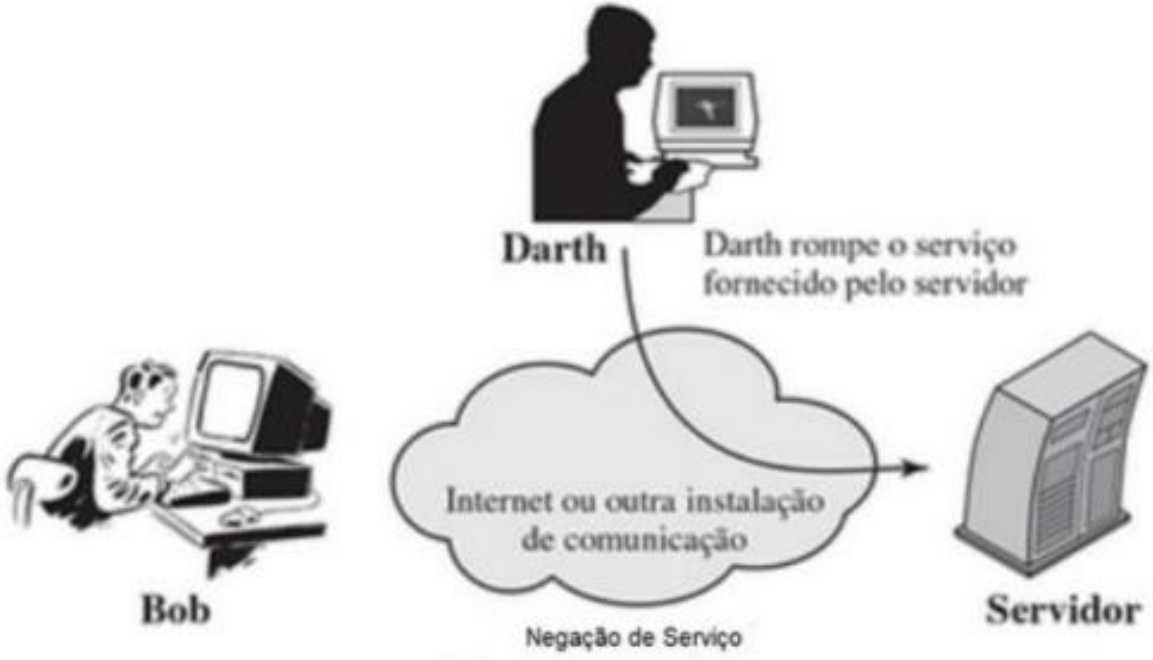
# Ataque Ativo – Modificação de Mensagem

- Uma parte da mensagem originalmente transmitida é alterada ou adiada ou reordenada visando à produção de efeito não autorizado

Fonte: (STALLINGS, 2008, p. 8).

# Ataque Ativo - Negação de Serviço

- Ocorre um impedimento ou inibição para utilização ou gerenciamento das instalações de comunicação . Também é conhecido como **Denial of Service ( DoS )** .




Fonte: (STALLINGS, 2008, p. 8).

# Ataque Ativo – Negação de Serviço

Tal ataque pode possuir um alvo específico ou perturbar a rede como um todo, de modo a sobrecarregá-la com mensagens ou desativá-la, com o intuito de prejudicar seu desempenho.

Dois principais tipos de ataque de negação de serviço :

- **Grande quantidade de tráfego**
  - O agente de ameaças dispara uma enorme quantidade de dados a uma taxa que a rede, host ou aplicativo não pode manipular. Com isso, o tempo de resposta do host atacado irá aumentar, causando lentidão para os demais usuários ou até uma interrupção do serviço.
- **Pacotes maliciosamente formatados**
  - O invasor envia um pacote formatado maliciosamente para um host ou aplicativo e o receptor não consegue manipulá-lo. Isso causa lentidão ou falha na execução do dispositivo receptor.

# Ataques Ativos

Os ataques ativos se aproveitam das vulnerabilidades físicas , de software e da rede e deve - se atuar na sua detecção , visando recuperar - se de rompimentos ou atrasos causados por esse tipo de ataque .

Há uma categoria de ataques denominada **ataques mistos** , nos quais são utilizadas mais de uma técnica para se infiltrar no sistema e atacá-lo .

**Os ataques mais modernos são enquadrados nessa categoria**

# Ataque de Dia Zero (Zero Day Attack)

Explora as vulnerabilidades de software antes dessas se tornarem conhecidas ou antes de serem divulgadas pelo fabricante de software

# Categorias de Ataques mais comuns

| Categoria de Ataque | Descrição |
|---|---|
| Ataque de escuta | Um ataque de espionagem ocorre quando um agente de ameaça captura e escuta o tráfego da rede. Esse ataque também é chamado de *sniffing* ou *snooping*. |
| Ataque de modificação de dados | Ataques de modificação de dados ocorrem quando um agente de ameaça capturou o tráfego da empresa e alterou os dados nos pacotes sem o conhecimento do remetente ou receptor. |
| Ataque de Falsificação de Endereços IP | Um ataque de falsificação de endereço IP ocorre quando um ator de ameaça constrói um pacote IP que parece se originar de um endereço válido dentro da intranet corporativa. |
| Ataques baseados em senha | Ataques baseados em senha ocorrem quando um ator de ameaça obtém as credenciais de uma conta de usuário válida. Em seguida, os atores de ameaças usam essa conta para obter listas de outros usuários e informações de rede. Eles também podem alterar as configurações de servidor e rede e modificar, redirecionar ou excluir dados. |
| Ataque de negação de serviço (DoS) | Um ataque de DoS impede o uso normal de um computador ou rede por usuários válidos. Depois de obter acesso a uma rede, um ataque DoS pode travar aplicativos ou serviços de rede. Um ataque de DoS pode inundar um computador ou toda a rede com tráfego até que um desligamento ocorra devido à sobrecarga. Um ataque de DoS também pode bloquear o tráfego, o que resulta na perda de acesso aos recursos da rede por usuários autorizados. |
| Ataque Man-in-the-Middle (MitM) | Um ataque MitM ocorre quando os agentes da ameaça se posicionam entre a origem e o destino. Agora eles podem monitorar, capturar e controlar ativamente a comunicação de forma transparente. |
| Ataque de chave comprometida | Um ataque de chave comprometida ocorre quando um ator de ameaça obtém uma chave secreta. Isto é referido como uma chave comprometida. Uma chave comprometida pode ser usada para obter acesso a uma comunicação segura sem que o remetente ou o destinatário esteja ciente do ataque. |
| Ataque *Sniffer* | Um *sniffer* é um aplicativo ou dispositivo que pode ler, monitorar e capturar trocas de dados de rede e ler pacotes de rede. Se os pacotes não estiverem criptografados, um *sniffer* fornece uma visão completa dos dados dentro do pacote. Até mesmo pacotes encapsulados podem ser quebrados abertos e lidos, a menos que sejam criptografados e que o ator de ameaça não tenha acesso à chave. |

Fonte: (CISCO, 2021)

# Domínio de Ameaça

**Área de controle, autoridade ou proteção que atacantes pode explorar para ganhar acesso ao sistema, através de exploits(Ferramentas de ataque).**

- Acesso físico direto ao sistema ou redes;
- Redes sem fio dentro dos limites da empresa;
- Equipamentos com comunicação via Bluetooth ou NFC
- Anexos de e - mail maliciosos;
- Contas de mídias sociais de uma empresa, tais como Twitter, Facebook, Instagram;
- Mídias removíveis como pen - drives;
- Aplicações baseadas em nuvem.

## Conceitos...

Vamos aprofundar nosso conhecimento sobre os pilares da segurança da informação. Para construir uma defesa sólida, primeiro precisamos **entender exatamente contra o que estamos nos protegendo**

# Vamos relembrar: Conceitos...

Os conceitos de ameaça, vulnerabilidade e mitigação são fundamentais e **se conectam** o tempo todo.

- Uma **vulnerabilidade** é uma **fraqueza** em um sistema ou processo.
- Uma **ameaça** é a **causa potencial de um incidente** que pode explorar essa fraqueza.
- E a **mitigação**, também chamada de contramedida ou salvaguarda, é a **ação que tomamos para reduzir o risco** de que essa ameaça aconteça.

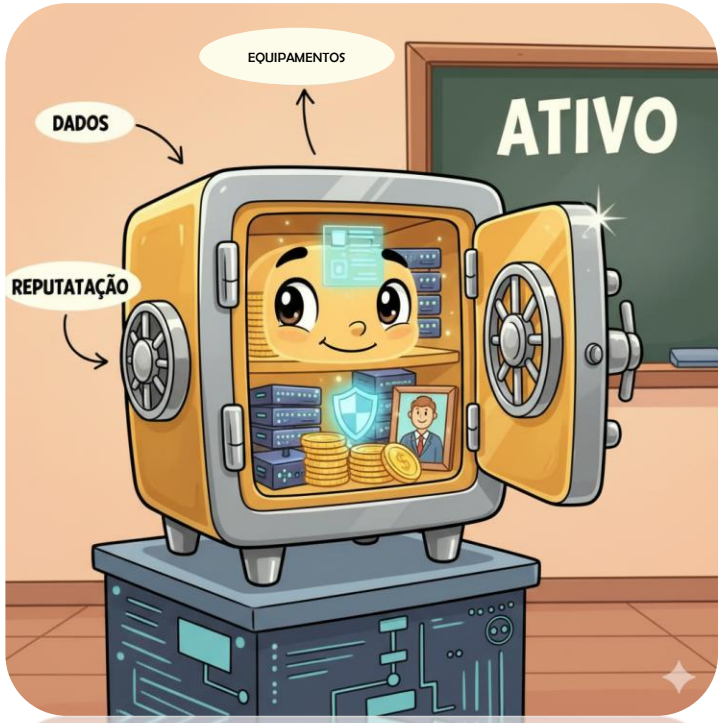
# Conceitos: ATIVOS

Tudo começa com algo de valor.
Em segurança da informação, chamamos isso de **Ativo**.

Um ativo é, de forma bem simples, **qualquer coisa que tenha valor** para a organização.

Isso pode ser:

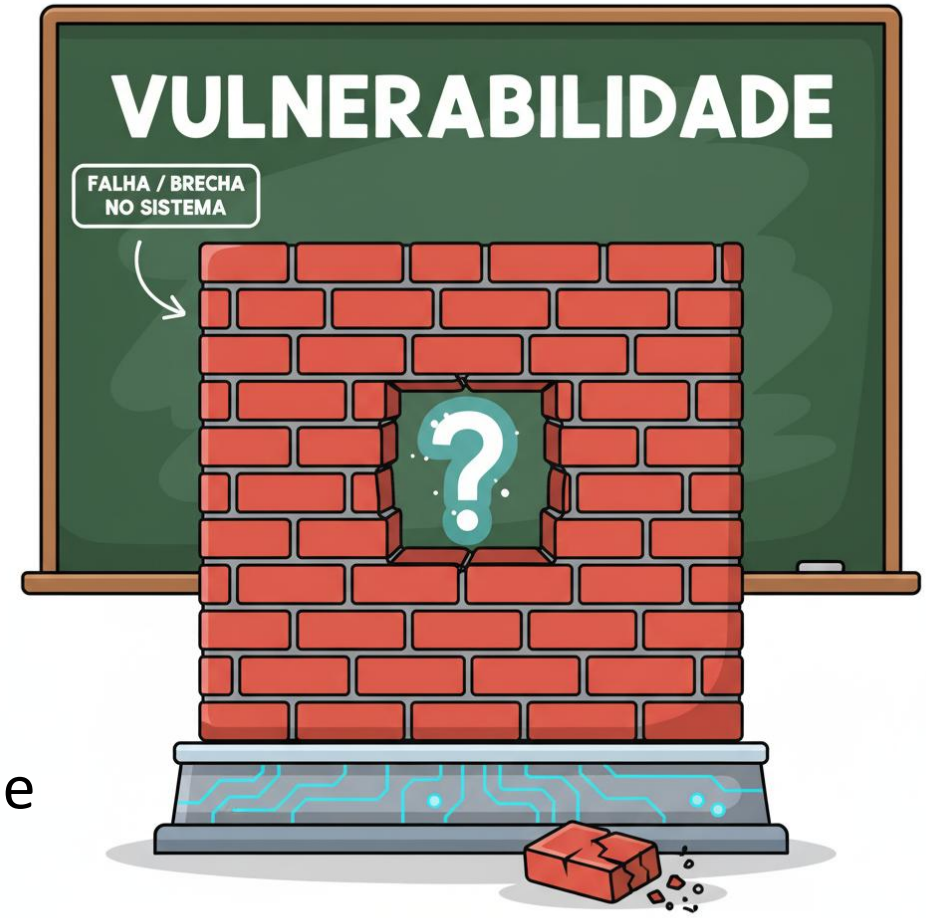
- A informação em si (como dados de clientes)
- Os equipamentos (servidores, computadores)
- Os programas de computador
- Coisas intangíveis, como a reputação da empresa.



# Conceitos: Vulnerabilidades

Vulnerabilidade é uma **fraqueza** de um ativo que pode ser explorada por uma ameaça. Exemplos:

- Uma porta sem tranca
- Uma janela aberta ou
- Um software desatualizado.




É uma falha na proteção que está lá, esperando que algo ou alguém a explore.

# Conceitos: Ameaça e Agente Ameaçador

A **ameaça** é a **causa potencial de um incidente indesejado**, a qual pode resultar no dano a um sistema ou organização".

Pense na ameaça como o ladrão que está passando na rua e pode notar a porta destrancada.

A ameaça pode ser:

- Um hacker tentando invadir a rede.
- Um desastre natural, como um incêndio ou enchente, que pode destruir o equipamento.
- Até mesmo um funcionário que comete um erro sem querer e apaga um arquivo importante.

**A entidade que se aproveita da vulnerabilidade é chamada de agente ameaçador.**

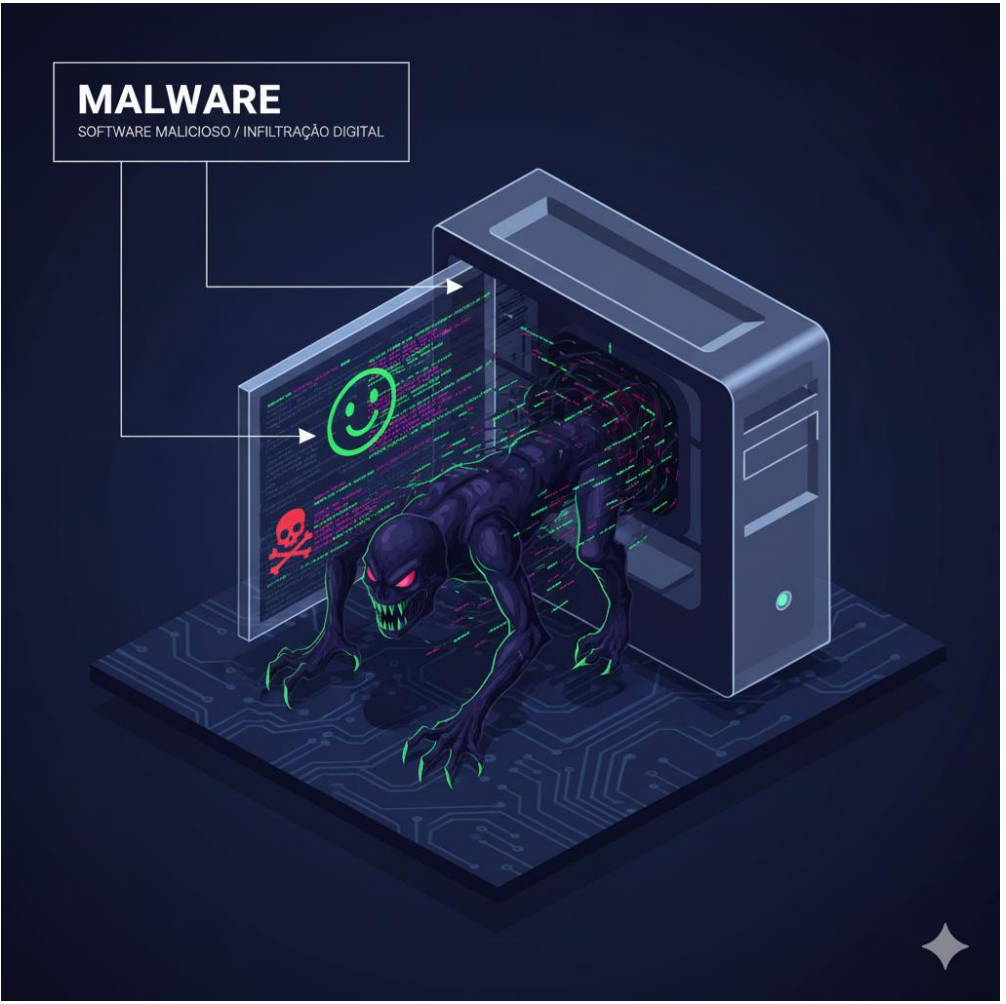
# Conceitos: Ataques

Um **ataque é a exploração de uma vulnerabilidade por uma ameaça**.

Em outras palavras, é o **agente ameaçador** (como o hacker da nossa imagem) colocando em **prática** suas **intenções maliciosas**, aproveitando-se de uma falha no sistema.

O objetivo de um ataque geralmente é causar algum dano, obter acesso indevido ou comprometer a integridade, confidencialidade ou disponibilidade dos ativos.

# Conceitos: Malware




- **Malware (do inglês *malicious software*) é um termo genérico** para qualquer software projetado para causar **dano a um sistema, roubar dados ou obter acesso não autorizado** a um computador ou rede.
- Ele abrange uma **vasta gama de programas maliciosos**, cada um com suas características e objetivos específicos

# Ataques – Vírus

- Um vírus é um programa de computador que se anexa a um hospedeiro (um arquivo executável, um documento com macros) e se replica, espalhando suas cópias para outros arquivos hospedeiros.
- Ele **depende da ação humana para se propagar,** como executar um arquivo infectado ou abrir um documento contaminado.

# Ataques – Vírus

**Métodos de Propagação**

- Execução de programas infectados baixados da internet (especialmente de fontes não confiáveis).
- Abertura de anexos de e-mail maliciosos.
- Uso de mídias removíveis (como pen drives) contaminadas.
- Ativação de macros em documentos (Word, Excel, etc.)[3].
- **Principais Vítimas**
- Usuários finais que executam softwares de fontes desconhecidas.
- Empresas onde um único funcionário pode, sem saber, infectar toda a rede.

**Exemplos Notáveis**

- **Melissa (1999):** Um dos primeiros vírus de macro a ganhar notoriedade mundial.
- **ILOVEYOU (2000):** Propagou-se rapidamente por e-mail, causando prejuízos bilionários.

# Ataques – Worm

- Diferente do vírus, o worm é um malware autônomo que se replica e se propaga através de redes de computadores, explorando vulnerabilidades de segurança para infectar outros sistemas **sem a necessidade de intervenção humana.**
- Sua **capacidade de se espalhar automaticamente** o torna extremamente perigoso e rápido.

# Ataques – Worm

**Métodos de Propagação**

- Exploração de vulnerabilidades em sistemas operacionais e serviços de rede.
- Envio automático de cópias de si mesmo para listas de contatos de e-mail.
- Cópia para pastas de rede compartilhadas.

**Principais Vítimas**

- Sistemas e servidores com softwares desatualizados ou mal configurados.
- Redes corporativas inteiras, que podem ser paralisadas em questão de horas.

**Exemplos Notáveis**

- **Blaster (2003):** Explorou uma falha no Windows para se espalhar massivamente.
- **Storm Worm (2007):** Criou uma botnet gigante usando técnicas de engenharia social.
- **Stuxnet (2010):** Um worm altamente sofisticado projetado para atacar sistemas de controle industrial.

# Ataques – Cavalo de Tróia (Trojan Horse)

- Um Cavalo de Troia é um malware disfarçado de software legítimo e útil (um jogo, um protetor de tela, um aplicativo de produtividade).
- A vítima o executa voluntariamente, acreditando ser algo inofensivo.
- Uma vez ativo, ele abre uma "porta dos fundos" (backdoor) no sistema, permitindo que o invasor ganhe acesso não autorizado, roube informações ou instale outros malwares.
- Ele não se replica sozinho.

# Ataques – Cavalo de Tróia (Trojan Horse)

**Métodos de Propagação:**

- Download de softwares de sites não oficiais ou redes P2P (torrents).
- Anexos em e-mails de phishing que prometem algo interessante.
- Agrupado (bundled) com a instalação de outros programas gratuitos.

**Principais Vítimas:**

- Usuários que baixam e instalam software sem verificar a fonte.
- Jogadores e usuários em busca de software "gratuito" ou "crackeado".

**Exemplos Notáveis:**

- **BackOrrifice (2000):** Um famoso trojan de administração remota.
- **Netbus (1998):** Permitiam controle remoto total sobre máquinas Windows infectadas.

# Ataques – Botnet

- Uma botnet é uma **rede de computadores infectados, chamados de "zumbis" ou "bots",** que são controlados remotamente por um único atacante (o *botmaster*).
- Cada computador infectado se torna um soldado em um exército digital.
- Esse exército pode ser usado para realizar ataques em grande escala.

# Ataques – Botnet

**Métodos de Propagação:**

- A infecção inicial geralmente ocorre por meio de um Worm ou Cavalo de Troia que instala o "agente bot" no computador.

**Principais Vítimas:**

- Os "zumbis": Qualquer dispositivo conectado à internet com segurança fraca (PCs, roteadores, câmeras, etc.).
- Os "alvos": Empresas e serviços online que sofrem os ataques lançados pela botnet.

**Ataques aos Princípios:**

- Disponibilidade: O uso mais comum de uma botnet é para lançar ataques massivos de Negação de Serviço Distribuída (DDoS), sobrecarregando servidores e tornando-os indisponíveis.

# Ataques - Phishing

O Phishing é uma técnica de engenharia social que busca "roubar credenciais ou infectar o sistema da vítima por meio de uma mensagem“

**O objetivo é manipular a vítima para que ela forneça informações confidenciais** (como senhas, dados bancários, números de cartão de crédito) **ou execute alguma ação** (como clicar em um link malicioso ou baixar um anexo infectado)

## Métodos Usados

- **E-mails Falsos:** O método mais comum é o envio de e-mails que se disfarçam de instituições legítimas (bancos, empresas de tecnologia, serviços governamentais, etc.). Esses e-mails geralmente contêm links que levam a páginas falsas, idênticas às originais, onde a vítima é induzida a digitar suas credenciais.
- **Mensagens de Texto (Smishing):** Phishing via SMS, com links para sites maliciosos ou pedidos de informações
- **Chamadas Telefônicas (Vishing):** Phishing por voz, onde o criminoso se passa por alguém de confiança para obter informações **Redes Sociais:** Mensagens diretas ou postagens que parecem legítimas, mas contêm links para golpes ou sites maliciosos

# Ataques - Phishing

**Principais Vítimas**

- **Usuários em Geral:** Qualquer pessoa que utiliza e-mail, redes sociais ou smartphones pode ser vítima.
- **Funcionários de Empresas:** São alvos frequentes para obter acesso a redes corporativas, especialmente através de **Spear Phishing (phishing direcionado a indivíduos específicos).**
- Clientes de Bancos e Serviços Online: Alvos para roubo de dados financeiros

# Ataques - Phishing

## Ferramentas Conhecidas para Aplicar o Ataque

- **Kits de Phishing:** Pacotes pré-prontos que contêm páginas falsas, scripts e templates de e-mail para facilitar o ataque.
- **Ferramentas de Envio de E-mail em Massa:** Para disparar grandes volumes de e-mails falsos.
- **Frameworks de Engenharia Social:** Como o Social-Engineer Toolkit (SET), que automatiza a criação de páginas de login falsas e o envio de e-mails maliciosos
- **Domínios Falsos:** Registro de domínios semelhantes aos legítimos (ex: banc0.com em vez de banco.com) para aumentar a credibilidade do golpe

# Ataques - Ransomware

O Ransomware é um tipo de software malicioso que, após infectar um sistema, **criptografa os dados da vítima ou bloqueia o acesso ao sistema, exigindo um resgate** (geralmente em criptomoedas) para restaurar o acesso.

É como ter seus **arquivos sequestrados** digitalmente.

## Métodos Usados

- **E-mails de Phishing:** Frequentemente, o ransomware é entregue via anexos maliciosos ou links em e-mails de phishing.

- **Exploração de Vulnerabilidades:** Pode explorar falhas de segurança em sistemas operacionais ou softwares (ex: EternalBlue, que foi usado pelo WannaCry) para se espalhar em redes.

- **Downloads Maliciosos:** Através de sites comprometidos ou anúncios malvertising que levam a downloads de software infectado [cite: 594].

- **Ataques de Força Bruta a RDP (Remote Desktop Protocol):** Criminosos tentam adivinhar senhas de acesso remoto para servidores e, uma vez dentro, instalam o ransomware.

# Ataques - Ransomware

## Principais Vítimas

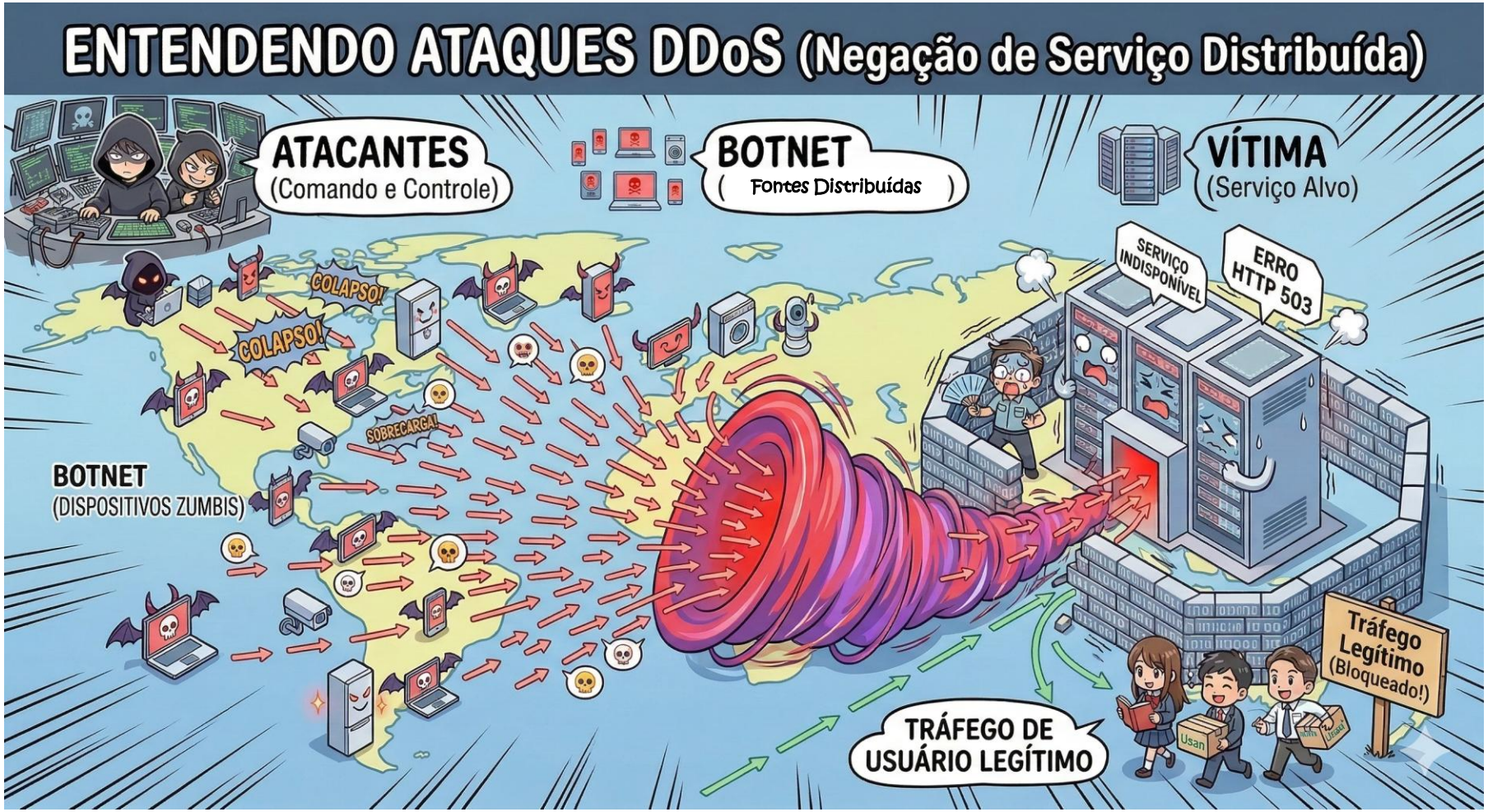
- **Empresas e Organizações:** São alvos primários devido à sua capacidade de pagar resgates maiores e à dependência de seus dados para operar Inclui hospitais, órgãos governamentais, indústrias e pequenas empresas.
- **Usuários Domésticos:** Embora menos lucrativos, ainda são alvos e podem perder fotos, documentos e outros arquivos pessoais .

# Ataques - Ransomware

**Ferramentas Conhecidas para Aplicar o Ataque:**

- **Variantes de Ransomware:** Existem inúmeras famílias de ransomware, como WannaCry, Petya/NotPetya, Ryuk, Maze, Conti, LockBit, entre outras, cada uma com suas próprias técnicas de criptografia e propagação .
- **Kits de Exploração (Exploit Kits):** Software que automatiza a detecção e exploração de vulnerabilidades em sistemas para injetar o ransomware .
- **Serviços de RaaS (Ransomware-as-a-Service):** Permitem que indivíduos com pouca habilidade técnica lancem ataques de ransomware, utilizando infraestrutura e ferramentas fornecidas por outros, em troca de uma porcentagem do resgate .

# Ataques - DDoS



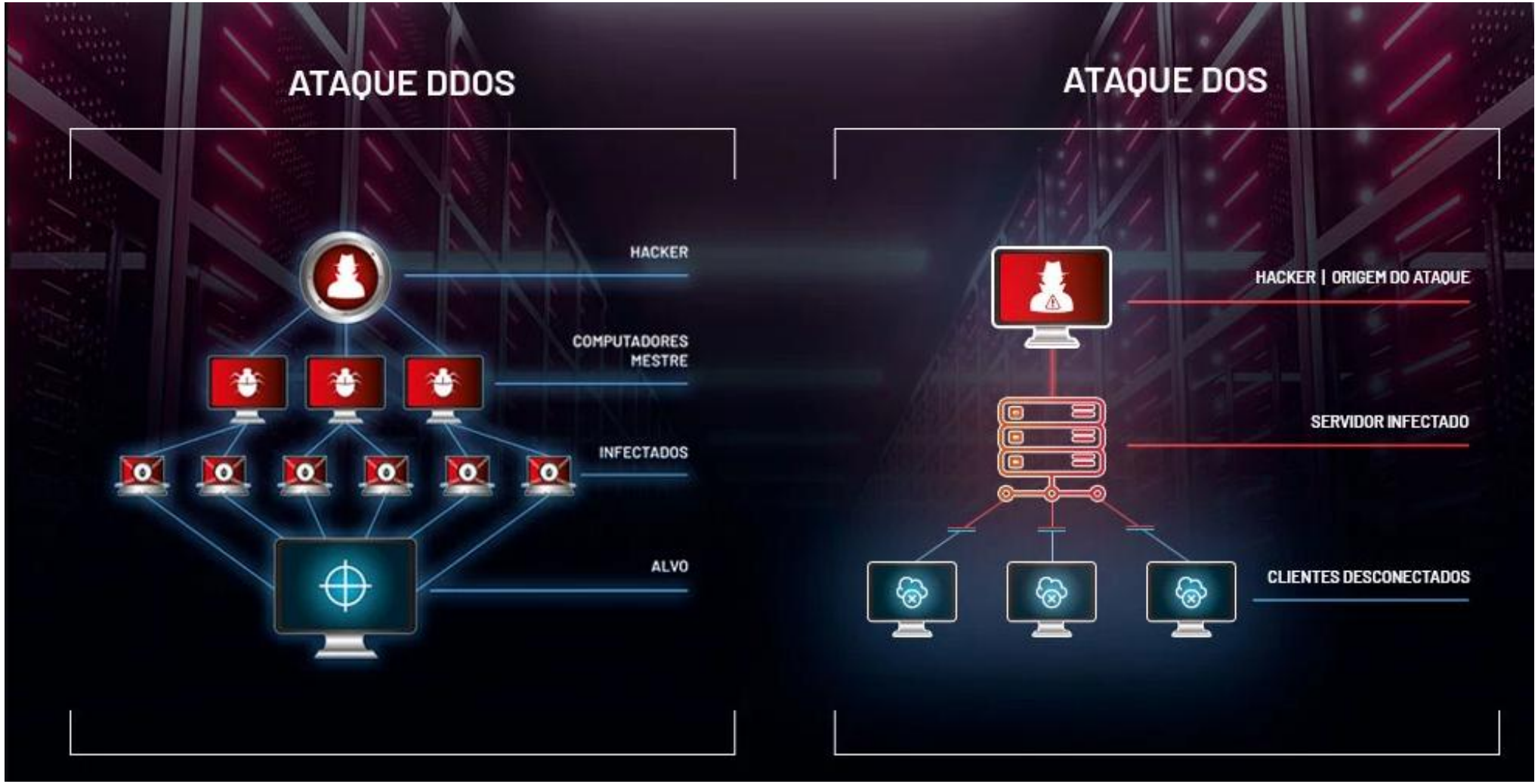

**Ataques de Negação de Serviço (DoS) e Negação de Serviço Distribuída (DDoS)**

Os ataques DoS e DDoS têm como objetivo tornar um serviço, servidor ou rede inacessível aos seus usuários legítimos . Imagine que o site do seu banco ou seu e-commerce favorito de repente para de funcionar porque está sobrecarregado.

# Ataques - DDoS

- **DoS (Denial of Service):** Geralmente utiliza uma única fonte (um computador) para gerar tráfego excessivo ou consumir recursos, sobrecarregando o alvo .
- **DDoS (Distributed Denial of Service):** É uma versão mais potente e difícil de mitigar do DoS, pois utiliza múltiplas fontes (uma rede de computadores comprometidos, conhecida como botnet) para inundar o alvo com tráfego .

# Ataques - DDoS



# DNS cache poisoning

- O que é: Inserção de registros DNS falsos no cache do resolvedor.
- Como funciona: Respostas forjadas com ID/porta corretos chegam antes da resposta legítima.
- Sinais/Exemplos: Domínios comuns resolvendo para IPs estranhos; aumento de alertas de phishing.
- Mitigações: DNSSEC, randomização de porta/ID, recursão validada, higiene de forwarders e split-horizon.

I A C

# Rogue DHCP

- O que é: Servidor DHCP não autorizado fornece gateway/DNS malicioso.
- Como funciona: Compete com o DHCP legítimo e 'vence' a corrida de oferta.
- Sinais/Exemplos: Clientes com gateway/DNS errados; rotas fora do padrão; perda de conectividade.
- Mitigações: DHCP Snooping, portas 'trusted' bem definidas, 802.1X/NAC, isolamento de usuários.

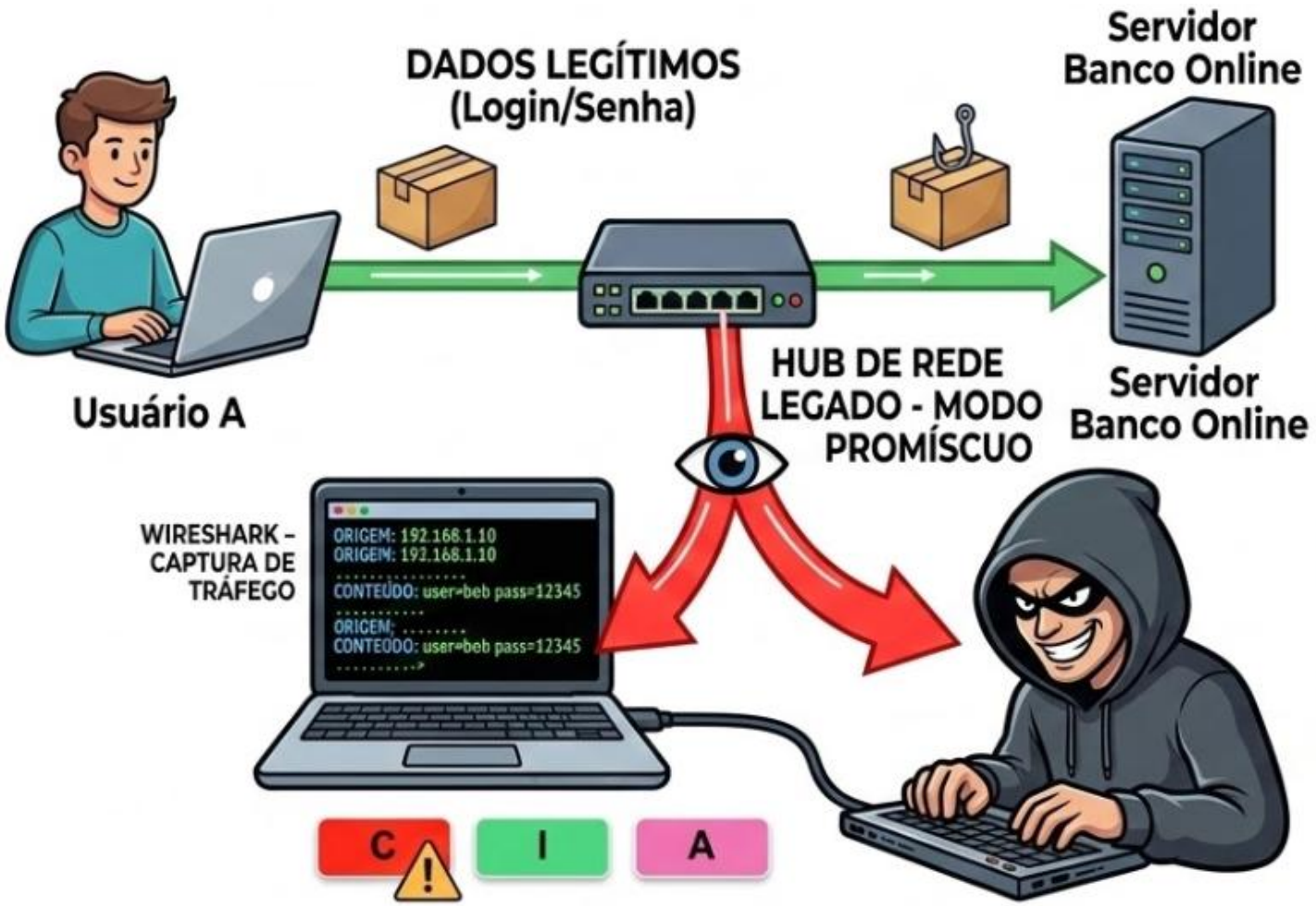
C I D A

# TCP hijacking

- O que é: Sequestro de sessão TCP ativa.
- Como funciona: Previsão/observação dos números de sequência para injetar/assumir o fluxo.
- Sinais/Exemplos: Resets anômalos; comandos inesperados; saltos no estado da sessão.
- Mitigações: TLS/VPN, filtros anti-spoofing, IDS/IPS, segmentação, cookies TCP.

C I A

# Sniffing de tráfego claro




- **O que é:** Escuta passiva de dados em trânsito em uma rede.
- **Como funciona:** Usando ferramentas (Wireshark, tcpdump) para ler pacotes em redes não criptografadas (ex: HTTP).
- **Impacto:** Exposição de logins, senhas, segredos industriais.
- **Mitigações:** Uso de criptografia (HTTPS, VPN, SSH), switches modernos (não hubs).

# Evil Twin (AP falso)

- O que é: Ponto de acesso 'gêmeo' imita SSID/portal para interceptar tráfego.
- Como funciona: Vítimas conectam e entregam credenciais/tráfego (sslstrip/mitm).
- Sinais/Exemplos: Vários APs com mesmo SSID; certificados TLS inválidos; portais suspeitos.
- Mitigações: WPA2-Enterprise/EAP-TLS com validação de certificado do servidor, 802.11w (MFP), WIPS, evitar auto-join.

C I A

# SQL Injection

- O que é: Injeção de comandos SQL por entrada não tratada.
- Como funciona: Concatenar input em queries permite ler/alterar dados ou executar comandos.
- Sinais/Exemplos: Erros SQL na tela; dumps de tabelas; alterações sem trilha.
- Mitigações: Prepared statements/ORM, validação por whitelist, least privilege no DB, WAF, gestão de segredos.

C I D A

# XSS (refletido/armazenado/DOM)

- O que é: Execução de JavaScript injetado no navegador da vítima.
- Como funciona: Input não higienizado é refletido/armazenado e roda no contexto do site.
- Sinais/Exemplos: Pop-ups inesperados; roubo de cookies; alteração do DOM.
- Mitigações: Escapes contextuais, CSP, cookies HttpOnly/SameSite, sanitização de HTML, frameworks que auto-escapam.

C I A

# Buffer overflow

- O que é: Estouro de buffer desvia o fluxo de execução (stack/heap).
- Como funciona: Grava além do limite e injeta ROP/código arbitrário.
- Sinais/Exemplos: Crashes; comportamento errático; shells inesperados.
- Mitigações: Linguagens memory-safe, ASLR, DEP/NX, stack canaries, fuzzing, validação de limites.

I D C

# Privilege escalation

- O que é: Ganho de privilégios além do permitido (vertical/horizontal).
- Como funciona: Abuso de SUID/ACLs, serviços vulneráveis, bugs de kernel/módulos.
- Sinais/Exemplos: Processos como root sem justificativa; alterações sistêmicas; logs anômalos.
- Mitigações: Least privilege, hardening (SELinux/AppArmor), patching contínuo, remover SUID desnecessário, EDR.

C I D

# Tailgating (intrusão física)

- O que é: Entrar em área restrita 'no carona' atrás de alguém autenticado.
- Como funciona: Engenharia social e portas sem mantrap/torniquete.
- Sinais/Exemplos: Pessoas sem crachá em zonas seguras; acessos sem registro.
- Mitigações: Mantrap/torniquete, challenge culture, vigilância, política rígida de visitantes.

A C I

# Shoulder surfing / dumpster diving

- O que é: Espiar telas/teclados ou vasculhar lixo para coletar dados.
- Como funciona: Observação direta/filmagem; coleta de papéis/mídias descartadas.
- Sinais/Exemplos: Informações sensíveis visíveis; descarte comum de documentos.
- Mitigações: Filtros de privacidade, clean desk, trituradores, lixeiras seguras, mascaramento de dados.

C A

# ARP spoofing / poisoning

- O que é: Falsificação de respostas ARP para redirecionar tráfego na LAN.
- Como funciona: Atacante anuncia MAC como se fosse o gateway/host; vítimas atualizam cache ARP.
- Sinais/Exemplos: Mudanças suspeitas na tabela ARP; tráfego passando por host inesperado; quedas intermitentes.
- Mitigações: DHCP Snooping + DAI, 802.1X/NAC, VLANs/segmentação, monitoramento de ARP, IP/MAC estático em ativos críticos.

C I D A

# Ataques – Spyware

- Spyware é um tipo de malware projetado para espionar as atividades do usuário sem o seu conhecimento ou consentimento.
- Ele pode monitorar e coletar informações como histórico de navegação, senhas, dados pessoais e até mesmo pressionamentos de teclas (nesse caso, é chamado de ***keylogger***)

# Ataques – Spyware

**Métodos de Propagação**

- Instalado junto com softwares gratuitos (freeware).
- Através da exploração de vulnerabilidades em navegadores de internet.
- Clicando em pop-ups ou anúncios enganosos.

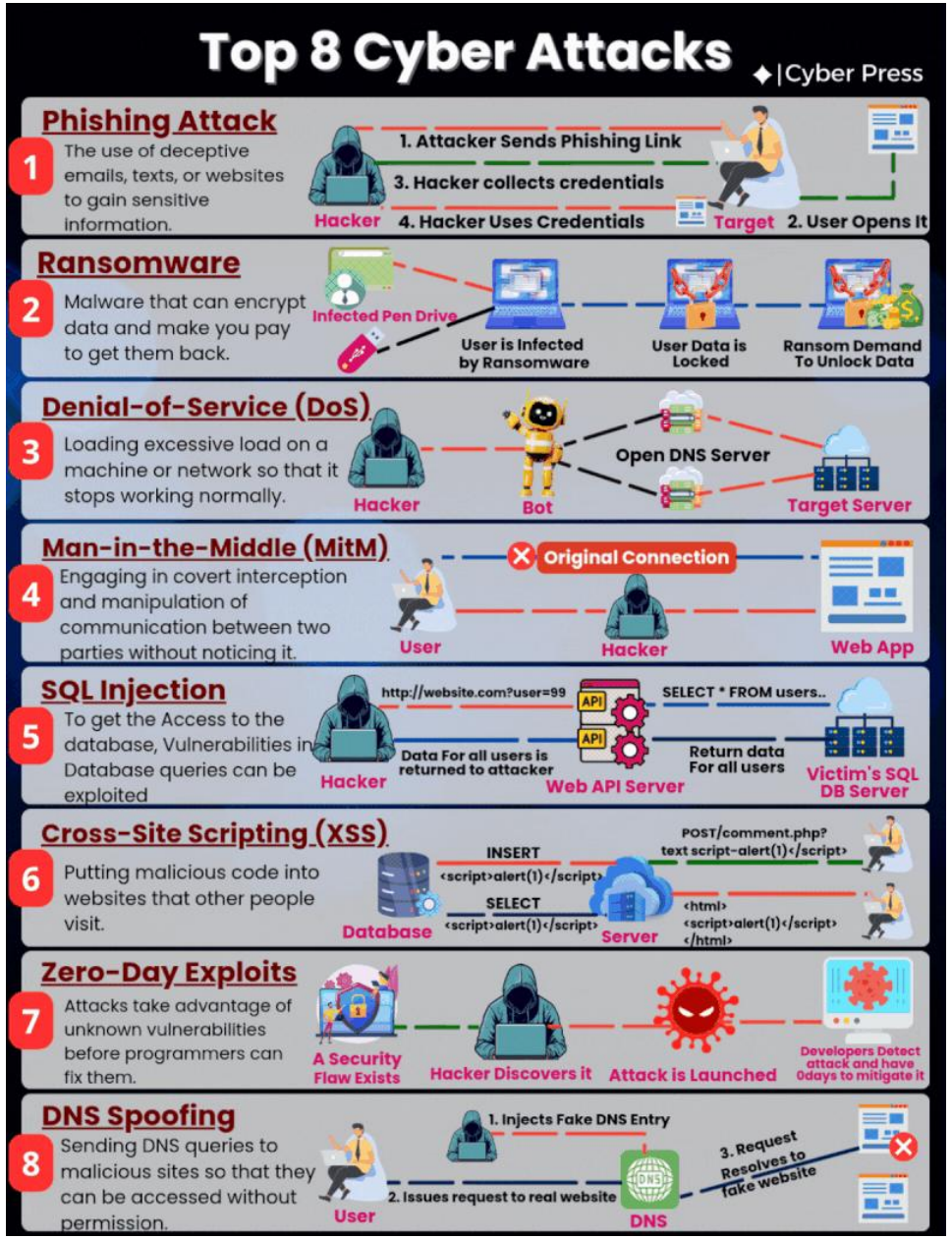
**Principais Vítimas**

- Qualquer usuário da internet, mas especialmente aqueles que instalam muitos programas gratuitos ou navegam em sites de reputação duvidosa.

**Ataques aos Princípios**

- **Confidencialidade:** É o principal alvo. O spyware vaza informações privadas e sensíveis do usuário para o atacante.

# Cenário Atual




**A imagem ilustra os principais ataques registrados em 2025**

**Fonte:**

**https://www.linkedin.com/feed/update/urn:li:activity:7430038640883462144/**

CEUB

EDUCAÇÃO SUPERIOR